Enhanced Cloud Security

Member Services DevOps

yahoo!

Agenda

1. **Current practices**
   - Account Security
   - Network Security
   - Application Security
   - Example Deployment
2. **Future refinements and improvements**
   - Route53 Logging and Firewall
   - Ensure that deployed applications are not running as ‘root’
   - Audit and adjust all Security Groups with refined egress controls

yahoo!

Agenda

- Improved IAM Policy management
  - AWS Access Analyzer External
  - AWS Access Analyzer Internal
- AWS Config Rules
- AWS Network Firewall
- AWS Cloudwatch Insights with anomaly detection
- Catching GuardDuty and Cloudtrail events locally
- Next steps and LOEs

yahoo!

Current Practices

yahoo!

Account Security

Account Segmentation and general account security measures.

- Applications are separated into separate accounts based on security level, content, or access requirements
- Accounts are peered only with specific network requirements such as (*)centralized database access
- DEV and PROD environments are separated at the account level
- User access is controlled via Athenz with our DMT tool to ensure centralized management
- All accounts have AWS Guard Duty enabled by default and monitored by Paranoids
- Cloudtrail is enabled by default and events monitored by Paranoids
- Yahoo Gacco is deployed by default and monitors cloud governance compliance

yahoo!

Network Security

All accounts have VPC's built to specific minimum requirements to ensure a platform to deploy applications is both secure and consistent

- VPC's built with dual network zones
    - Public - Attached to an IGW for Load Balancers
    - Private - No IGW, uses Managed NAT's for egress, no public ingress
- Independent NACLs for each zone
- Independent Route Tables for each zone
- Localized DNS resolution via Route 53
- AWS Public API access terminated with internal endpoints where possible

yahoo!

Application Security

Applications are deployed with standardized frameworks meeting the following requirements

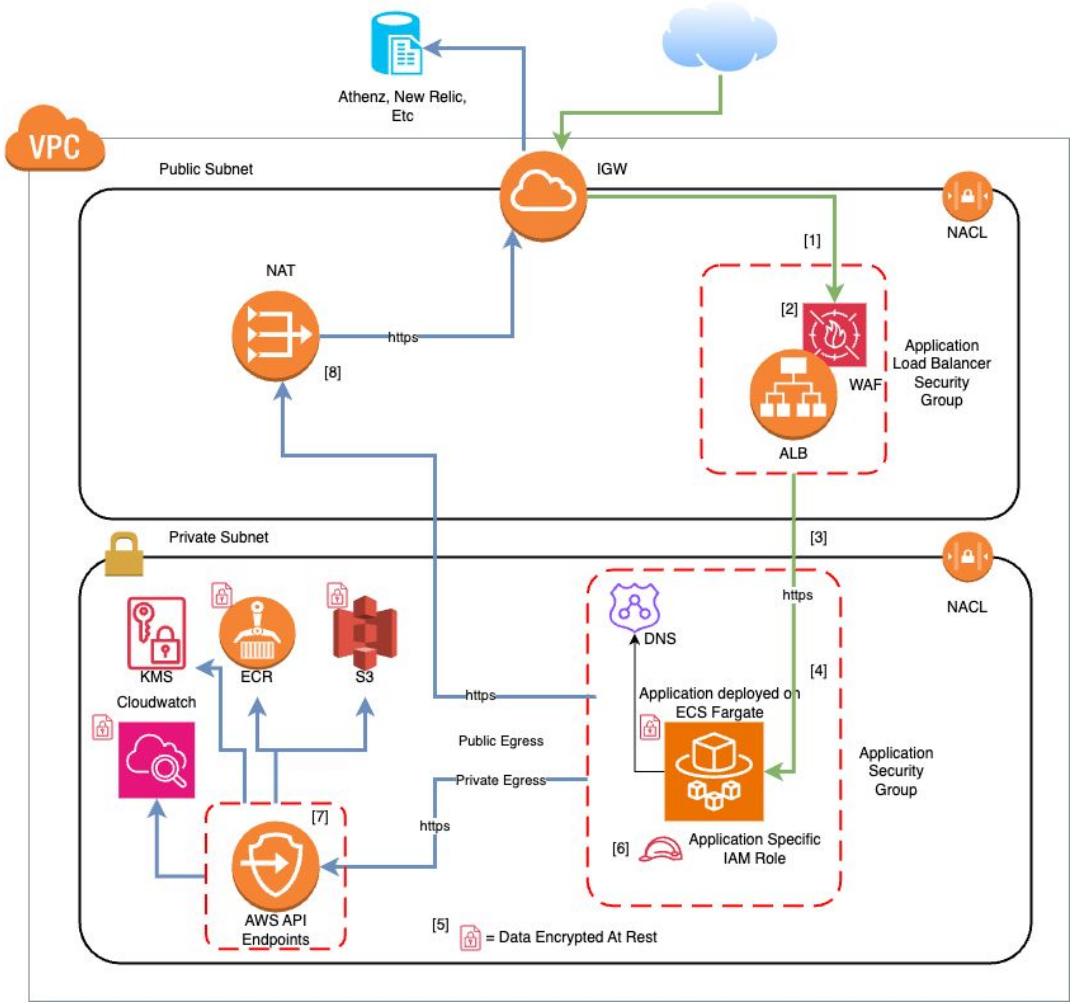
- Applications have their own unique Security Groups (Stateful Firewalls)
- Load balancers have their own unique Security Groups per application
- Each application get it's own unique IAM role with limited permissions as needed
- Most production applications are deployed in Serverless environments with no SSH access
- EC2 based applications deploy with security daemons by default (Nessus and SentinelOne)
- AMI's for EC2 built on specially hardened Icarus images
- Application containers scanned for security issues automatically in the registry by default
- ALB's protected via Web Application Firewall (WAF)

yahoo!

Example Deployment

Key Security Features for a standard serverless deployment

- [1] - L4 Firewall (SG) in front of Load Balancer
- [2] - L7 Firewall (WAF) in front of Load Balancer
- [3] - Traffic to application encrypted
- [4] - L4 Firewall (SG) in front of application
- [5] - All data encrypted at rest
- [6] - Application Specific IAM Role used for permissions
- [7] - All necessary AWS API endpoints terminated internally inside the VPC
- [8] - Public API endpoints egress through managed NAT service



yahoo!

Future refinements and improvements

yahoo!

Route53 Logging and Firewall

Problem: Prevent data exfiltration via DNS and limit software inside the VPC to known domains

- CSC v7.1 CSC-7-7 Use of DNS Filtering Services
- NIST SP 800-53 SC-21 Secure Name / Address Resolution Service

Solution: Enable both Route53 DNS Logging and Route53 Firewall solutions at the VPC level

- Shared ‘allow list’ group from central account applied first with common domains
- Individual rule groups deployed specific to each VPC’s needs
- DENY all rule can be set for either BLOCK or ALERT
    - BLOCK will fail all requests not allowed
    - ALERT will trigger both a Cloudwatch Log entry and a Guard Duty finding

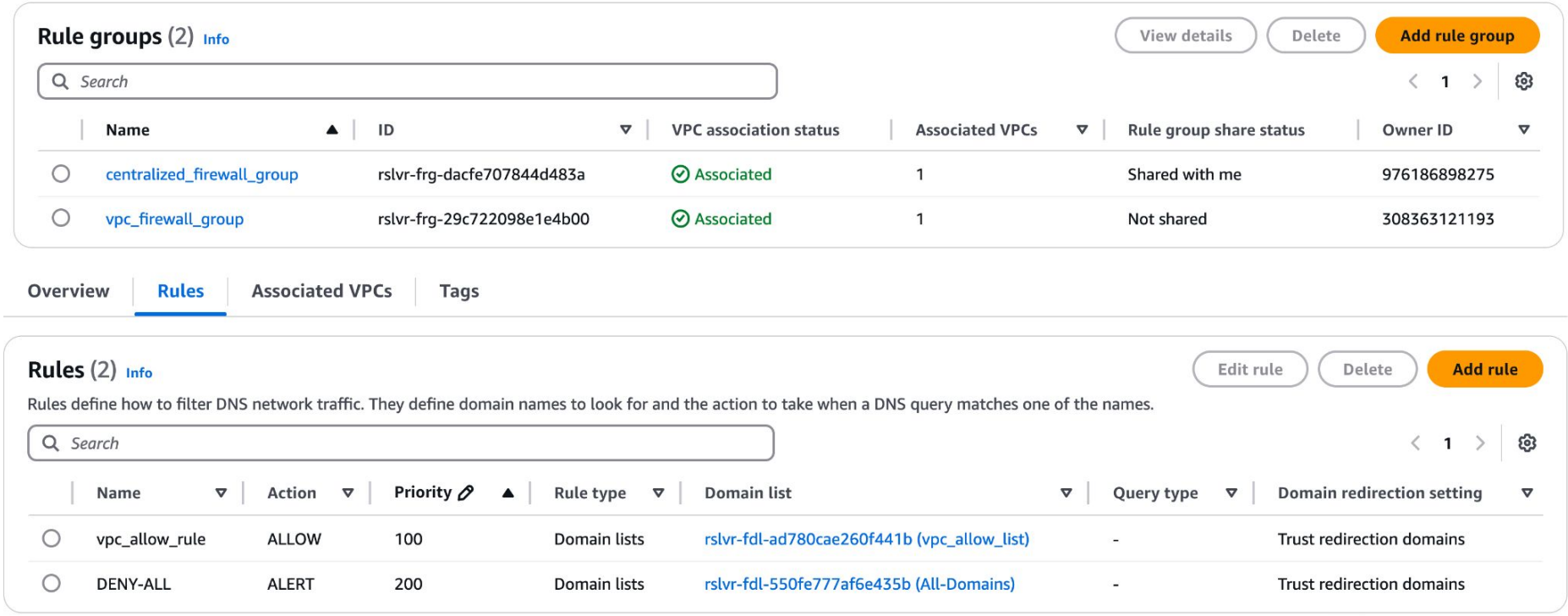
Challenges:

- In BLOCK mode undocumented or unexpected changes resolution requirements could break applications
- In ALERT mode we might be made aware of an issue but would not have stopped it



yahoo!

Route53 Logging and Firewall



Rule groups (2) Info

View details | Delete | Add rule group

Search

1

Name	ID	VPC association status	Associated VPCs	Rule group share status	Owner ID
centralized_firewall_group	rslvr-frg-dacfe707844d483a	Associated	1	Shared with me	976186898275
vpc_firewall_group	rslvr-frg-29c722098e1e4b00	Associated	1	Not shared	308363121193

Overview | Rules | Associated VPCs | Tags

Rules (2) Info

Edit rule | Delete | Add rule

Rules define how to filter DNS network traffic. They define domain names to look for and the action to take when a DNS query matches one of the names.

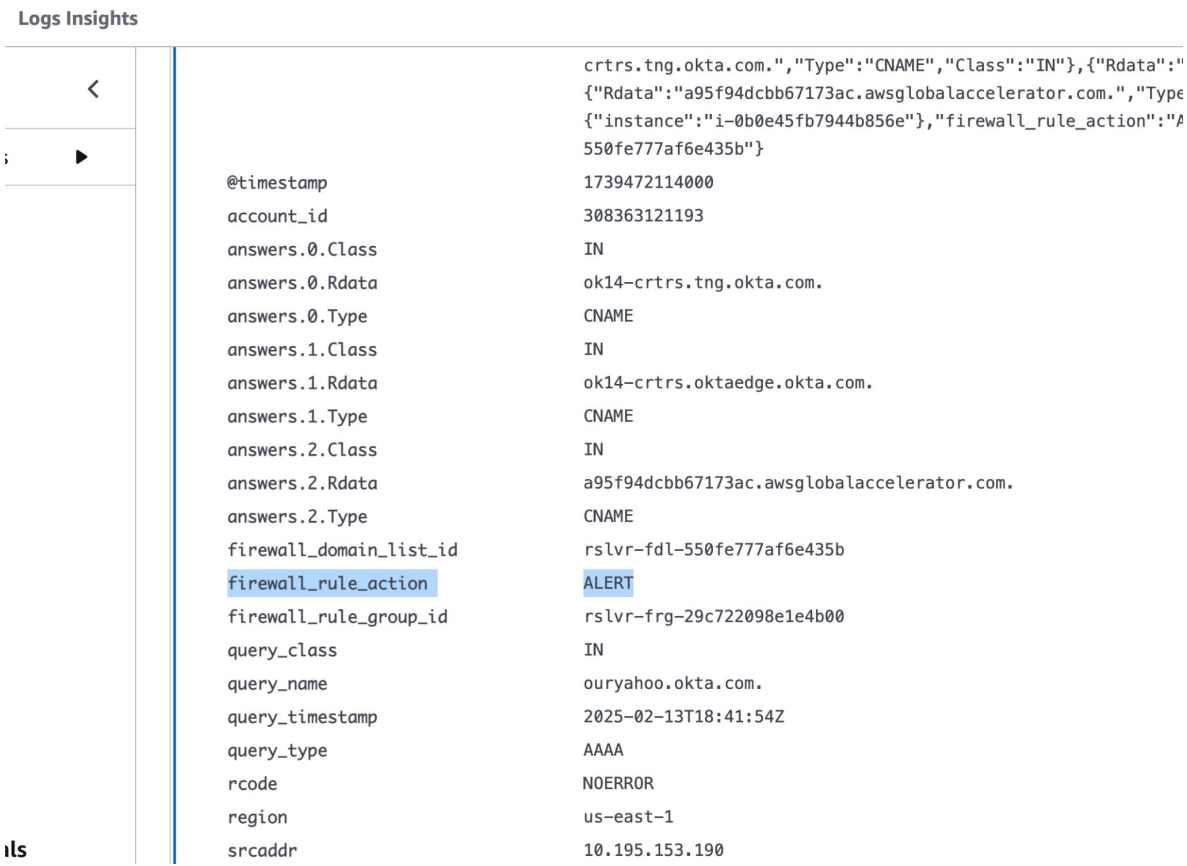
Search

1

Name	Action	Priority	Rule type	Domain list	Query type	Domain redirection setting
vpc_allow_rule	ALLOW	100	Domain lists	rslvr-fdl-ad780cae260f441b (vpc_allow_list)	-	Trust redirection domains
DENY-ALL	ALERT	200	Domain lists	rslvr-fdl-550fe777af6e435b (All-Domains)	-	Trust redirection domains

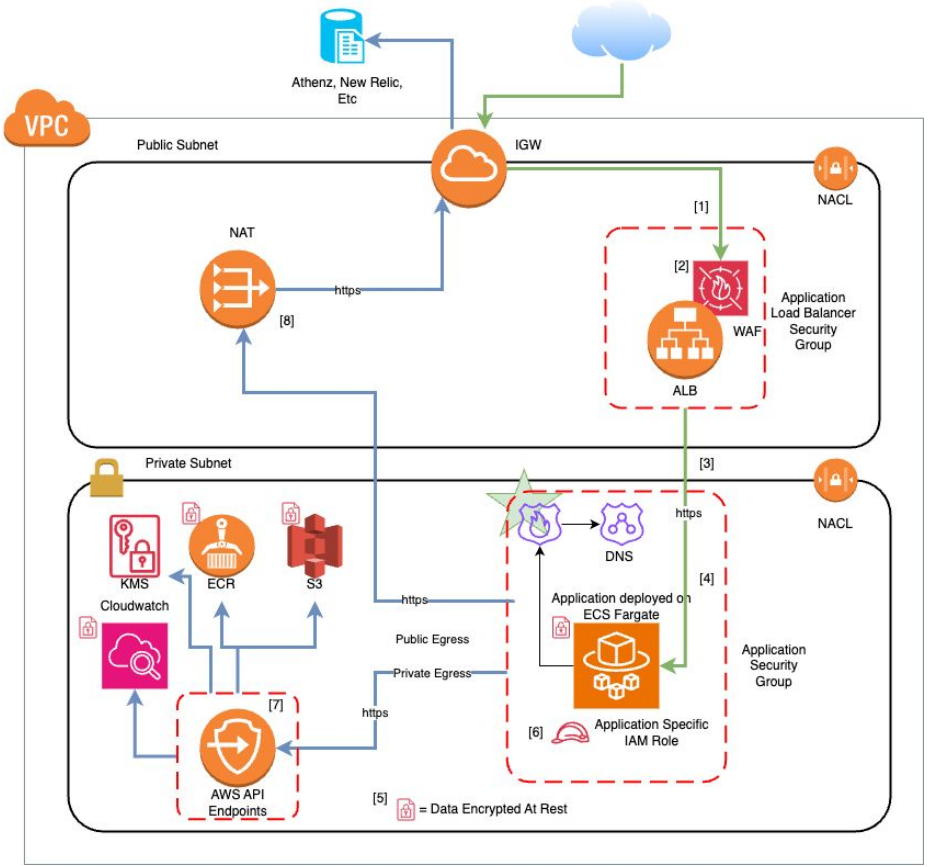
yahoo!

Route53 Logging and Firewall



yahoo!

Route53 Logging and Firewall



yahoo!

Ensure that deployed applications are not run as ‘root’

Problem: Running your application as root in a serverless container environment increases the risk of privilege escalation and full container compromise if the application is exploited.

- CIS Docker Benchmarks Ensure that containers do not run as root
- NIST 800-53 SI-7 Reduces the risk of malware running with high privileges

Solution: Serverless deployments natively support setting a specific non-root user in the task definition. The proposal will be to change either the ‘container build’ or ‘deploy’ step in our pipelines to fail if a non-root user is not specified for the application.

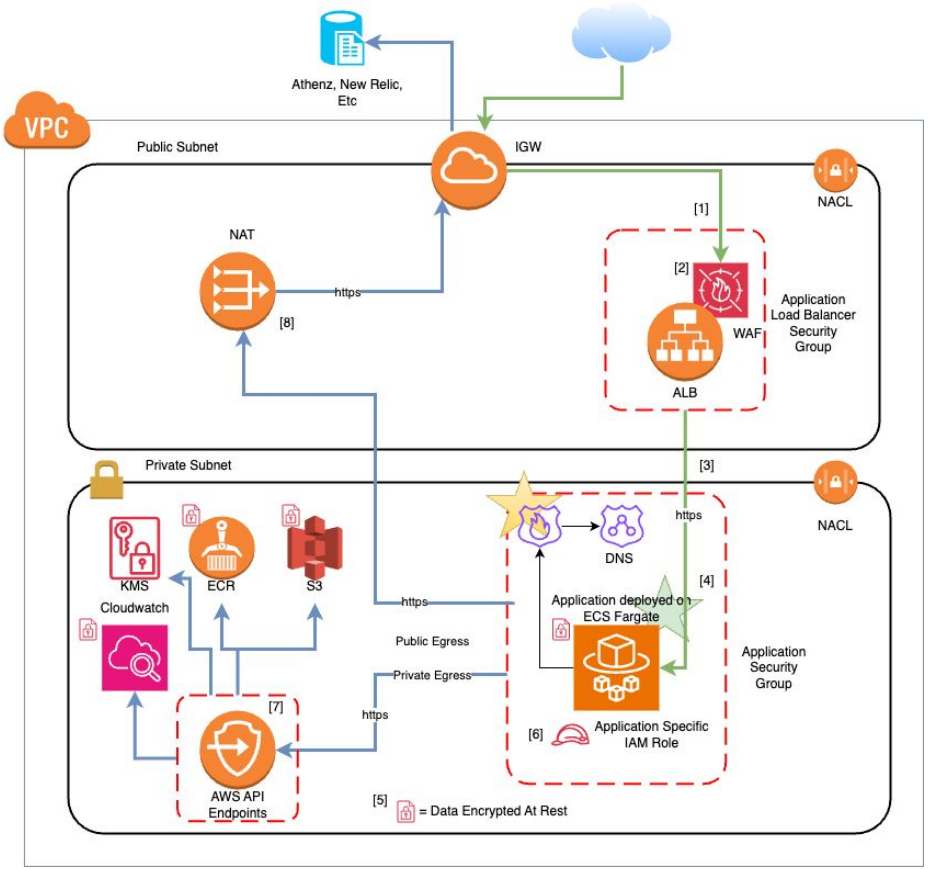
- Fargate Documentation
- Existing Example Deployment (NewsBalance)

Challenges:

- Applications must be updated one by one and if running as a non-root user causes errors there might be code or build changes required to resolve the issue

yahoo!

Ensure that deployed applications are not run as ‘root’



yahoo!

Audit and adjust all SGs with refined egress controls

Problem: Prevent data exfiltration, limit communication to only approved destinations, and reduce the risk of malware or compromised applications calling out to unauthorized or malicious endpoints.

- NIST SP 800-53 AC-4: Information Flow Enforcement

Solution:

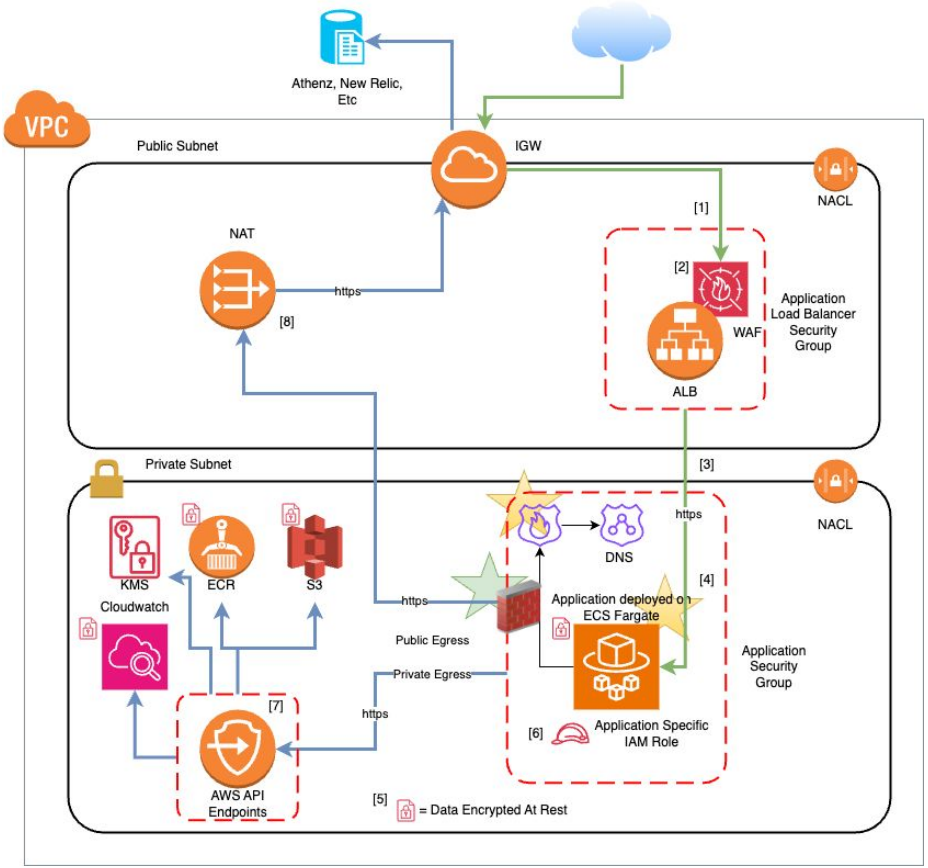
- Step 1: Identify and publish shared “Managed Prefix Lists” for known endpoints (Athenz, New Relic) from a centralized account. This reduces future management for global changes [COMPLETE]
- Step 2: Identify required AWS endpoints and deploy them to the VPC to localize AWS API calls [PARTIAL]
- Step 3: For each application identify unique endpoints for that application and build custom security group egress rules. Add managed lists from step 1 to this group
- Step 4: To ensure compliance a monitoring and reporting system must be implemented to ensure new systems brought online meet the standard and old ones are not manually changed

Challenges:

- Each application will have unique requirements and it’s possible some might need access to dynamic external public sources that make this impractical

yahoo!

SGs with refined egress controls



yahoo!

Improved IAM Policy management

Problem: Without precise, least-privilege access controls, unauthorized access can escalate, causing widespread damage across systems and data. Strengthening IAM policies is essential to limit lateral movement, reduce potential damage, and ensure more resilient application security in the face of breaches.

- NIST SP 800-53 AC-3 (Access Enforcement) and AC-6 (Least Privilege)

Solution:

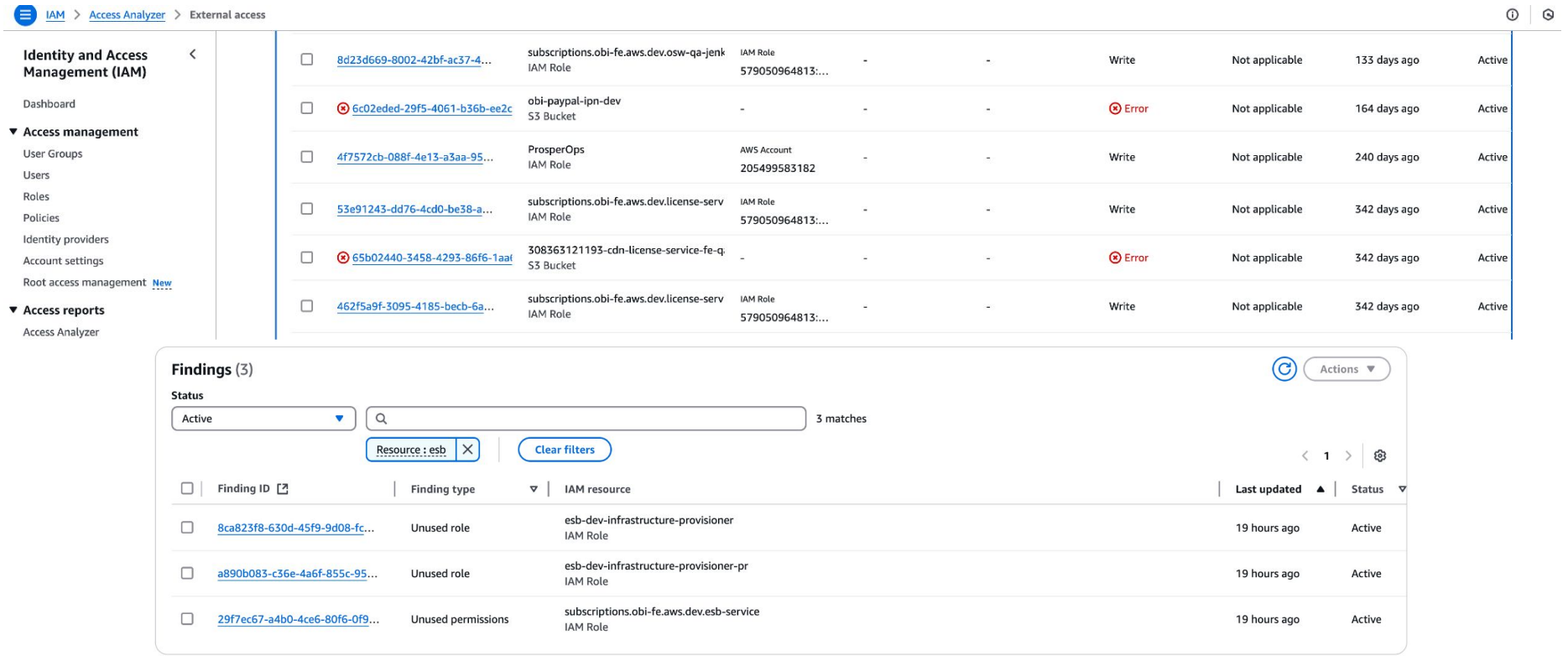
- One time audit for each identified application to review current IAM Policies.
  - Using results from Access Analyzer to verify unused permissions that can be removed
  - Apply conditional statements where possible
  - Add statements to DENY use outside of the VPC to prevent token use if exfiltrated
- Enable and configure use of Access Analyzer External
- Enable and configure use of Access Analyzer Unused Permissions

Challenges:

- Some familiarity with application requirements will be needed

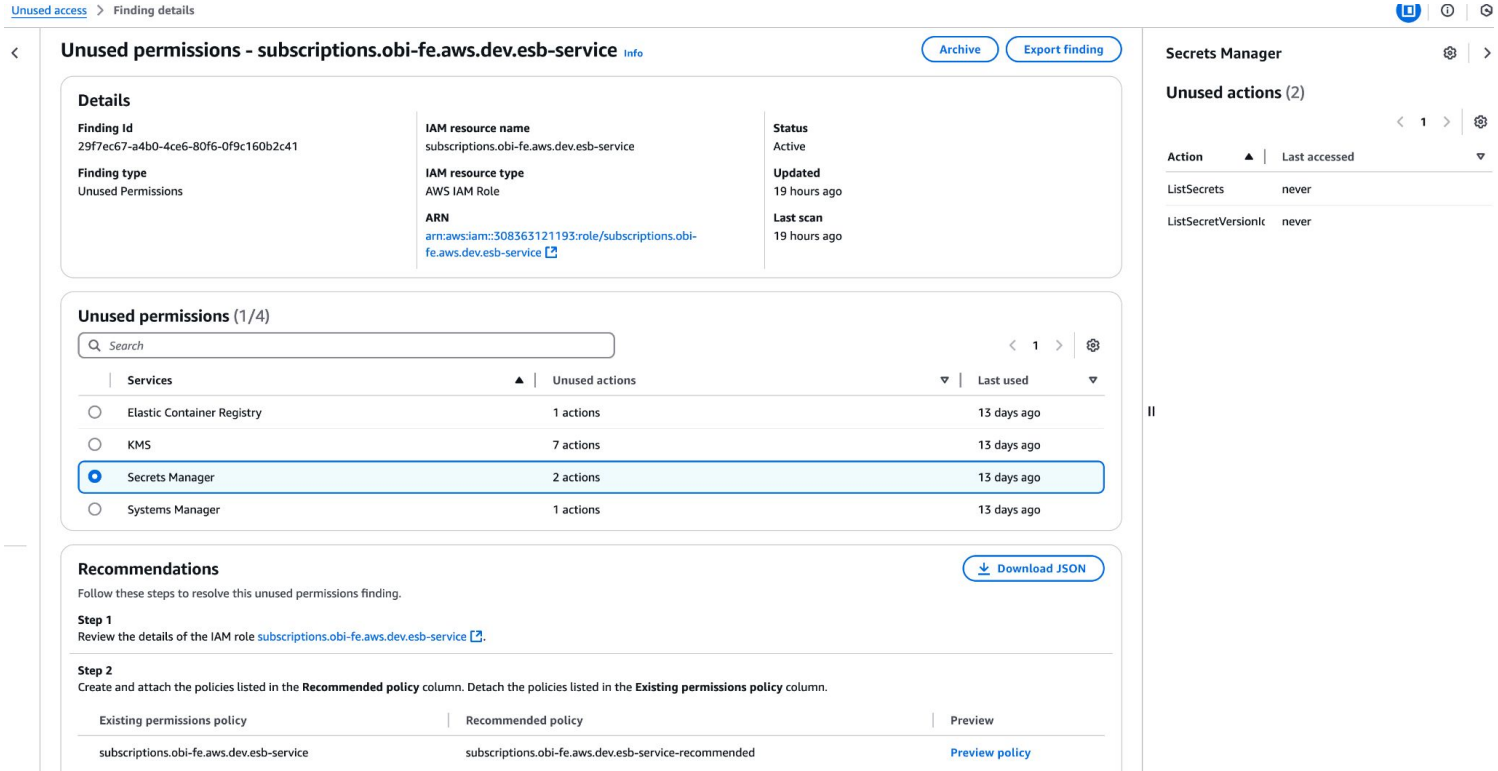
yahoo!

Access Analyzer



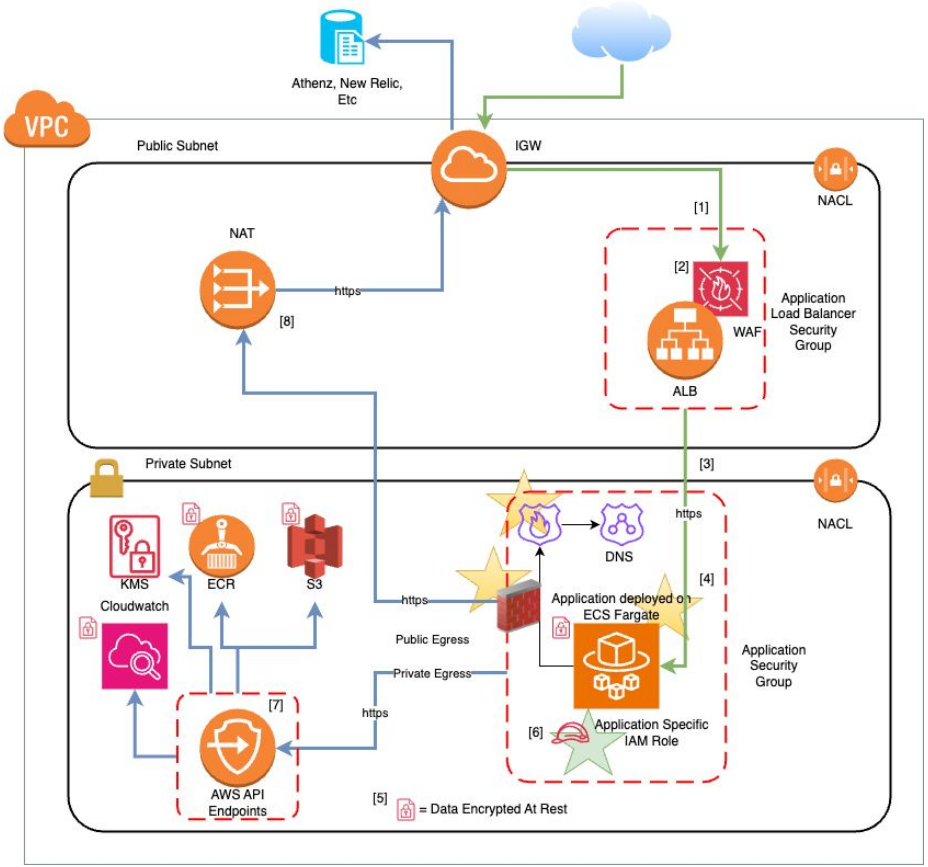
yahoo!

Access Analyzer



yahoo!

Improved IAM Policy management



yahoo!

AWS Config Rules

Problem: Over time resources can drift by manual changes and new deployments being tested might break existing rules we've defined. We need a way to constantly monitor and enforce our requirements even through manual and uncommitted changes.

Solution: AWS Config is already enabled in all our accounts to track resource configuration and acts as both a troubleshooting tool and security tool. AWS Config Rules are declarative rules that can be applied to almost any AWS resource to ensure it meets our standards.

Challenges: Once deployed and the initial clean up of all non-compliant resources is done we need an automated way to notify of problems that arise in the future.

Example:

- We want to enforce that any security group in our account has a limited egress policy and does not allow unrestricted egress to the public

yahoo!

AWS Custom Config Rules

security-group-rule.guard

```
rule EC2_SECURITY_GROUP_EGRESS_OPEN_TO_WORLD when resourceType == "AWS::EC2::SecurityGroup" {

  # Check if the security group has the exception tag
  let has_exception_tag = configuration.tags[
      key == "exception_egress"
    ]

  # Check to see if the security group contains unbound egress rules
    let open_egress = configuration.ipPermissionsEgress[
      some ipv4Ranges[*].cidrIp == "0.0.0.0/0"
      OR
      some ipv6Ranges[*].cidrIp == "::/0"
    ]

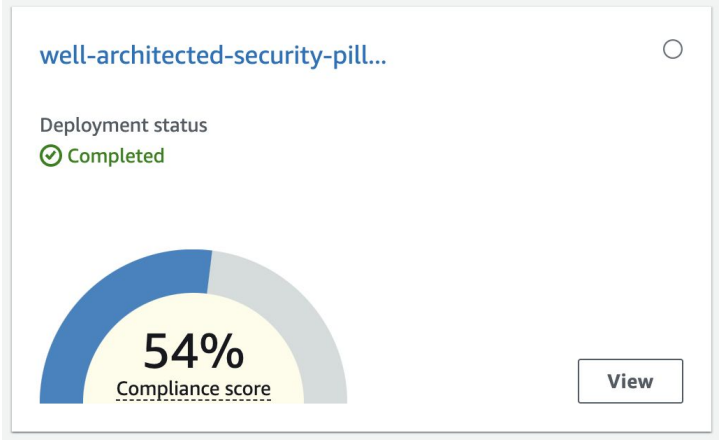
  # If `has_exception_tag` has values in it a tag was found thus TRUE
  # The following OR clause will give us the logic we need for excempting rules

  %has_exception_tag not empty
  OR
  %open_egress empty
  <<
    Violation: Security group allows unrestricted egress traffic to the world.
    Fix: Restrict outbound rules to specific IP ranges instead of 0.0.0.0/0 or ::/0.
  >>
}
```

yahoo!

AWS Conformance Packs

- Conformance packs can contain a mixture of AWS Managed pre-configured rules and custom user defined rules.
- Once built they can be easily deployed and managed across all accounts to ensure consistent enforcement.
- No additional account resources are required to run the rules



Rules (128)

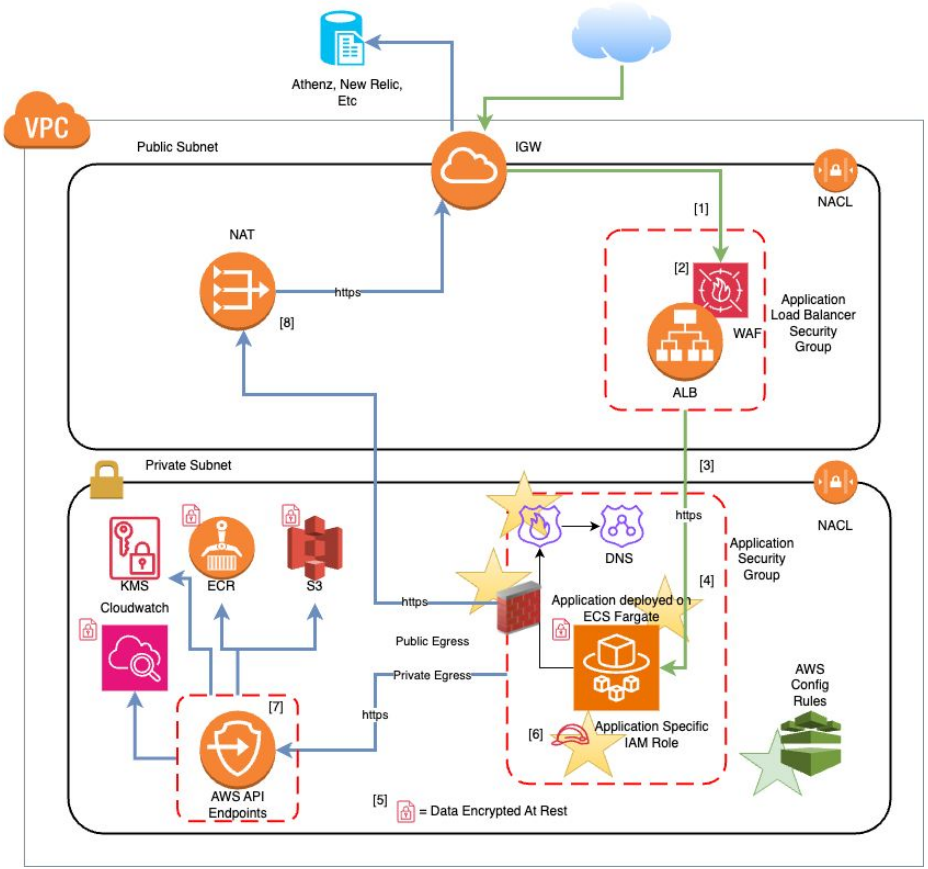
Filter rules by name or compliance status

1 2 3 4 5 6 7 ... 13

Name	Remediation action	Type	Controls	Compliance
ecs-containers-nonprivileged-conformance-pack-g0zxbxhdb	Not set	AWS managed	-	Compliant
elb-logging-enabled-conformance-pack-g0zxbxhdb	Not set	AWS managed	-	Compliant
ec2-security-group-attached-to-eni-periodic-conformance-pack-g0zxbxhdb	Not set	AWS managed	-	Noncompliant
waf-regional-webacl-not-empty-conformance-pack-g0zxbxhdb	Not set	AWS managed	-	Compliant
iam-policy-no-statements-with-full-access-conformance-pack-g0zxbxhdb	Not set	AWS managed	-	Noncompliant

yahoo!

AWS Config Rules



yahoo!

AWS Network Firewall

Problem: Our current VPC security relies heavily on Security Groups and Network ACLs, which provide only basic filtering. This leaves gaps in network visibility, intrusion prevention, and the ability to enforce advanced security policies, increasing the risk of unauthorized access and malicious traffic.

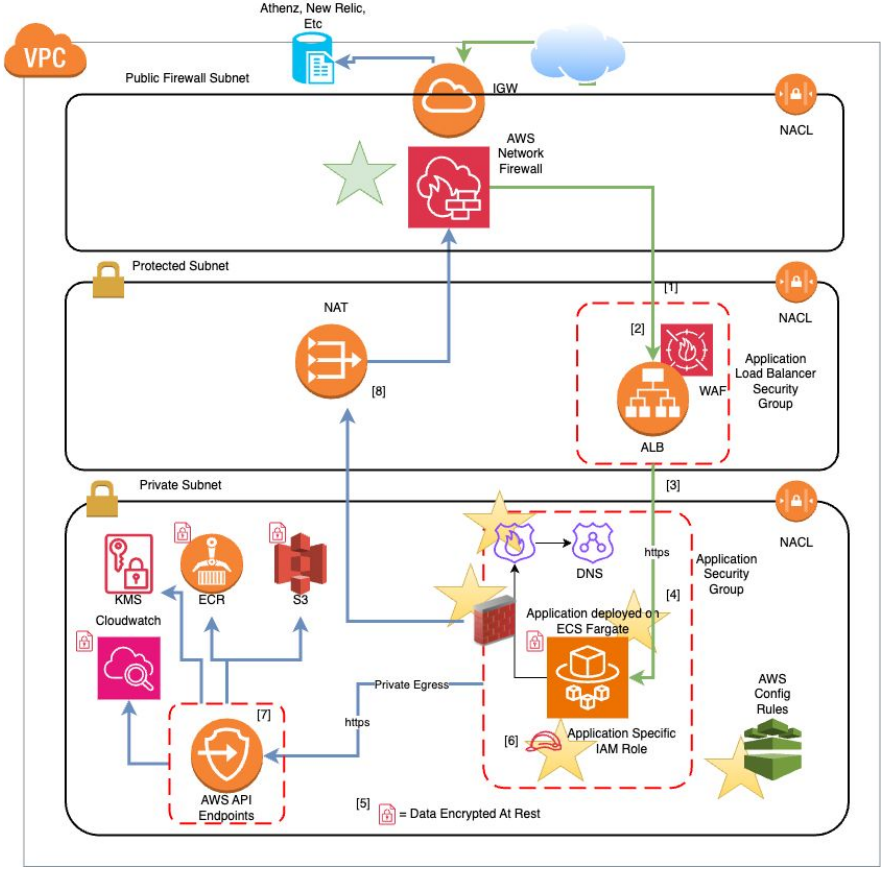
- NIST 800-53: SC-7 (Boundary Protection)

Solution: AWS Network Firewall enhances VPC security by providing deep packet inspection, intrusion detection and prevention (IDS/IPS), and customizable firewall rules. It allows us to enforce granular traffic controls, block known threats, and gain better visibility into network activity, significantly reducing the attack surface within our cloud environment.

Challenges: VPC's will need addition CIDRs assigned as our network space does not accommodate the required network layout. GAP modules do not support the network layout and new modules would have to be designed. The network transitions involved might incur a short network outage to the entire VPC while the main route tables are re-routed. This is a non-trivial network change. There will be additional costs.

yahoo!

AWS Network Firewall



yahoo!

AWS Cloudwatch Insights with anomaly detection

Problem: Application logs have alerts for known problems but we have no automated processes to identify new problems unless they directly impact the functionality for which tests monitor. This could allow attempts to attack the software go unnoticed.

Solution:

- AWS CloudWatch Logs Insights with anomaly detection can help identify new, previously unknown issues in application logs by continuously analyzing log data and automatically detecting unusual patterns or deviations from normal behavior. This capability enables proactive alerting on anomalies, even when they do not directly trigger known alerts or impact test-monitored functionality.

Challenges:

- Findings once discovered must be manually investigated and marked correctly as a problem or not in order to better train the model

yahoo!

Insights Anomaly Detection

Log anomalies (6) Info

Create alarm | Actions | View in Logs Insights | Create anomaly detector

The latest 50 anomalies are automatically updated every 1 minute

Filter anomalies by priority level, patterns or keywords

Group by: Time | Anomalies | Suppressed | 1

Inspect	Anomaly	Priority	Log pattern	Anomaly log trend	Last detection time	First detection time	Ano	Accurate?
	Anomalies ongoing that started recently (0)							
	Anomalies ongoing that started > 1h (0)							
	Anomalies identified but no longer happening (6)							
	33521.5% increase in log event count	High	[Token-1 Token-2 Number-3 Token-4 Number-5] [core:error] [pid Number-6:tid Number-7] [client Token-8] Token-9 invalid URI path (Token-10)		4 hours ago	14 days ago	farg	
	Unexpected pattern detected with severity ERROR	Medium	[Token-1 Token-2 Number-3 Token-4 Number-5] [ssl:error] [pid Number-6:tid Number-7] [client Token-8] Token-9 Hostname Token-10 provided via SNI, but no hostname provided in HTTP request		4 hours ago	14 days ago	farg	
	12163.3% increase in log event count	Medium	Token-1 Time-2,Number-3 ERROR [Token-4] utils.HttpUtils [] - parameter value is incorrect for parameter name: name-5 value Token-6 Token-7		11 hours ago	13 days ago	farg	
	Unexpected pattern detected with severity ERROR	Medium	[Token-1 Token-2 Number-3 Token-4 Number-5] [proxy:error] [pid Number-6:tid Number-7] (Number-8)Partial results are valid but processing is incomplete: [client Token-9] Token-10 prefetch request body failed to Token-11 (localhost) from IPv4-12 ()		1 day ago	1 day ago	farg	
	2781.8% increase in log event count	Medium	[Token-1 Token-2 Number-3 Token-4 Number-5] [proxy:error] [pid Number-6:tid Number-7] (Number-8)Connection refused: refused-9 http: attempt to connect to Token-10 (localhost:localhost-11) failed		2 days ago	2 days ago	farg	
	22743.5% increase in log event count	High	Token-1 Time-2,Number-3 ERROR [Token-4] rate.DBKeyRateUtil [Token-5] - no valid key found		14 days ago	16 days ago	farg	

yahoo!

Catching GuardDuty and Cloudtrail events locally

Problem: Currently while AWS GuardDuty and Cloudtrail are enabled and running in all our accounts the data is exported only to the Paranoids and we have no direct access to findings unless engaged by our security team

Solution:

- Using AWS Events Bridge we can grab GuardDuty findings ourselves and write them to a local cloudwatch logs group
- Secondary trails for cloudtrail can be enabled to duplicate all cloudtrail events into a local S3 bucket or Cloudwatch Log group

Challenges:

- Costs for secondary cloudtrail streams in all accounts has been approached before and was deemed too expensive for the benefit. We were requested to only run secondary streams where specifically necessary such as the PCI account

yahoo!

Next Steps and LOE's

Focus	LOE	RETURN	DEMO*
Route53 Logging and Firewall	MEDIUM	HIGH	4-6
Ensure that deployed applications are not run as 'root'	HIGH	MEDIUM	4-8
Audit and adjust all Security Groups with refined egress controls	VERY HIGH	HIGH	8-12
Improved IAM Policy management	HIGH	HIGH	16-24**
AWS Config Rules	LOW	LOW	8
AWS Network Firewall	VERY HIGH	HIGH	TBD
AWS Cloudwatch Insights with anomaly detection	LOW	LOW	Completed
Catching GuardDuty and Cloudtrail events locally	LOW	LOW	4-8**

* Estimated hours to complete MVP, not include writing modules/templates and documentation

yahoo!